



UNIVERSIDADE DE BRASÍLIA – UnB

Faculdade de Ciências e Tecnologias em Engenharia – FCTE

Arquitetura e Desenho de Software - FGA0208

**RELATÓRIO DE CASOS DE TESTES NO SITE DECATHLON: Fluxo Login e
Perfil, com ênfase em segurança para o usuário**

SubEquipe 01:

Dylan Portela Cavalcante – 231026984

Mariana Ribeiro Santana Gonzaga - 231026993

Rafaela Andrea Radamés Guerra – 231031723

Samuel Felipe Lira de Souza - 232022148

BRASÍLIA

2026

LISTA DE FIGURAS

<i>Figura 1: Falha de Login - cadastro inexistente</i>	8
<i>Figura 2: E-mail preenchido automaticamente</i>	8
<i>Figura 3: Página retornada após logout</i>	9
<i>Figura 4: Sistema aguardando a inserção do código de verificação</i>	9
<i>Figura 5: Código de verificação enviado por e-mail</i>	10
<i>Figura 6: Etapa de criação de senha</i>	10
<i>Figura 7: Alerta de CPF já usado em outra conta cadastrada</i>	11
<i>Figura 8: Resposta do sistema a senha digitada incorretamente</i>	12
<i>Figura 9: Procedimento de confirmação de alteração de senha</i>	12
<i>Figura 10: Etapa do processo de alteração de senha</i>	13
<i>Figura 11: Menu "Minha Conta" após processo de alteração de senha – Quebra de interface</i>	13
<i>Figura 12: Menu "Preferencias e Personalização" após processo de alteração de senha – Quebra de interface</i>	14
<i>Figura 13: Menu "Privacidade" após processo de alteração de senha – Quebra de interface</i>	14
<i>Figura 14: Menu "Segurança" após processo de alteração de senha – Quebra de interface</i>	14
<i>Figura 15: Opções de login - Fluxo de recuperação de senha</i>	15
<i>Figura 16: Sistema aguardando inserção de código de recuperação de senha</i>	15
<i>Figura 17: E-mail recebido com código de recuperação de senha</i>	16
<i>Figura 18: Sistema aguardando inserção de código de acesso único</i>	17
<i>Figura 19: Código de acesso único recebido por e-mail</i>	17

SUMÁRIO

1. INTRODUÇÃO	4
2. METODOLOGIA DE ENGENHARIA REVERSA E TESTES	5
3. CASOS DE TESTE E EVIDÊNCIAS.....	6
3.1. Tabela Consolidada dos Casos de Teste	6
3.2. Detalhamento dos Casos de Teste e Evidências	7
4. ANÁLISE CRÍTICA DOS RESULTADOS.....	18
4.1. Vulnerabilidades de Segurança e Privacidade	18
5. CONSIDERAÇÕES FINAIS.....	20

1. INTRODUÇÃO

Este relatório tem como objetivo registrar e analisar os resultados obtidos por meio de ensaios de teste operacionais e engenharia reversa comportamental na plataforma web da Decathlon. O foco central da análise concentrou-se nos fluxos de autenticação, cadastro de usuário, gestão de credenciais e controle de perfil de usuário.

A engenharia reversa comportamental foi adotada como estratégia para mapear o funcionamento real do sistema a partir da observação direta de suas respostas a diferentes estímulos de entrada, como por exemplo tentativas de login com dados válidos e inválidos, redefinição de senha e alteração de dados sensíveis.

Este levantamento empírico foi fundamental para o desenvolvimento do módulo Base do projeto da disciplina de Arquitetura e Desenho de Software, pois ofereceu os insumos e evidências necessárias para a produção de artefatos subsequentes deste. Os dados coletados nestes testes permitiram identificar vulnerabilidades, desvios de usabilidade e lacunas de segurança, fundamentando a especificação e a modelagem de requisitos não funcionais do sistema.

2. METODOLOGIA DE ENGENHARIA REVERSA E TESTES

A abordagem metodológica adotada para a execução deste estudo fundamentou-se na **Engenharia Reversa** combinada com o **Teste de Caixa-Preta** (*Black-Box Testing*). Esta estratégia foi escolhida por permitir a análise das regras de negócio, da arquitetura e dos mecanismos de segurança do sistema Decathlon sem a necessidade de acesso prévio ao seu código-fonte ou banco de dados.

A execução seguiu as seguintes etapas operacionais:

- **Mapeamento de Interfaces e Fluxos:** Identificação dos caminhos críticos de navegação do usuário, cobrindo os módulos de login (convencional e *passwordless*), cadastro manual, autenticação via provedores sociais (OAuth), alteração de credenciais e gestão de privacidade/dados pessoais.
- **Estimulação de Entradas e Análise de Respostas:** Submissão de dados válidos, inválidos e sintéticos (como e-mails inexistentes e senhas incorretas repetidas) para observar o comportamento das mensagens de validação e o fluxo de controle da aplicação.
- **Avaliação de Gestão de Sessão e Cache:** Verificação do comportamento da sessão de usuário após a execução do *logout*, testando a persistência de dados em cache por meio da navegação do histórico do navegador (botão "Voltar").
- **Análise de Conformidade com NFRs:** Agrupamento dos comportamentos observados segundo os atributos de Requisitos Não-Funcionais (NFRs), com foco principal em **Segurança** (Confidencialidade, Integridade, Autenticidade, Rastreabilidade) e **Usabilidade** (Consistência e Fricção de Navegação).

3. CASOS DE TESTE E EVIDÊNCIAS

Nesta seção, são apresentados os testes executados nos fluxos de autenticação, cadastro e gestão de perfil. As evidências capturadas (*screenshots*) sustentam a análise do comportamento real do sistema e fundamentam os achados de Requisitos Não-Funcionais (NFR)

3.1. Tabela Consolidada dos Casos de Teste

ID	TÍTULO DO CASO DE TESTE	AÇÃO EXECUTADA / ESTÍMULO	RESULTADO OBSERVADO	REQUISITO MAPEADO
CT-01	Enumeração de Usuários no Login	Inserção de e-mail inexistente	“Conta não encontrada..”	Confidencialidade
CT-02	Autenticação Social e Opt-in	Login via conta social (OAuth).	Exige 6 cliques e opt-in promocional	Usabilidade / Privacidade
CT-03	Encerramento de Sessão (Logout)	Clique em "Sair" e uso do botão "Voltar".	Redirecionamento para a tela de login.	Segurança da Sessão
CT-04	Validação via Código OTP	Cadastro manual e solicitação de código	Envio de OTP de 6 dígitos (15min)	Autenticidade
CT-05	Complexidade de Senha	Tentativa de cadastro de uma nova senha	Exigência de 8 dígitos, maiúscula, caractere especial, etc	Integridade
CT-06	Bloqueio por Múltiplas Falhas	Inserção de senha errada por 5 vezes	Retorno contínuo de “Senha inválida”	Resiliência / Defesa

CT-07	Redefinição de Senha no Perfil	Tentativa de reutilizar senha já usada	Alerta “Introduz outra palavra-passe”	Integridade
CT-08	Alerta de Alteração de Credenciais	Conclusão do processo de troca de senha	Nenhum e-mail de alerta foi enviado.	Rastreabilidade / Alerta
CT-09	Transição de Painel (SSO)	Acesso às opções avançadas de segurança	Redirecionamento para nova interface.	Consistência Visual
CT-10	Exclusão de Dados Pessoais	Busca por opções de cancelamento no perfil.	Presença do botão “Eliminar a minha conta”	Conformidade (LGPD)
CT-11	Esqueci minha senha (Recuperação)	Solicitada redefinição de senha informando o e-mail cadastrado	Envio de e-mail com link/código temporário para redefinição.	Recuperabilidade / Usabilidade
CT-12	Senha de acesso único	Solicitação de entrada direta sem senha fixa	Envio de token OTP por e-mail para acesso direto	Usabilidade / Autenticidade

Tabela 1: Tabela Consolidada de Casos de Testes

3.2.Detalhamento dos Casos de Teste e Evidências

CT-01: Mensagem de erro e enumeração de usuários

- **Procedimento:** Inserção do e-mail inexistente *rafaela.andrea@hotmail.com* na tela inicial de login.
- **Observação:** O sistema retornou o aviso *"Conta Decathlon não encontrada. Tente com outro email ou crie uma conta agora!"*.
- **Impacto em NFR:** Falha de Confidencialidade. Permite que um atacante identifique quais e-mails têm conta criada no sistema.

The image shows a login form titled "Login". It has a label "Digite seu email" above a text input field. The input field contains the email "rafaela.andrea@hotmail.com". Below the input field, there is a red error message: "Conta Decathlon não encontrada. Tente com outro email ou crie uma conta agora!". At the bottom of the form is a blue button labeled "PROSSEGUIR".

Figura 1: Falha de Login - cadastro inexistente

CT-02: Login social e permissões de dados

- **Procedimento:** Execução do fluxo de login com provedor externo.
- **Observação:** O processo exigiu um total de 6 cliques até a conclusão. Foi exigida a confirmação de aceite para e-mails promocionais. A política revela coleta de dados amplos (CPF, histórico de compras, esportes praticados) e dados sensíveis de saúde quando justificados no atendimento.
- **Impacto em NFR:** Usabilidade / Privacidade. Fricção na experiência do usuário e coleta extensiva de dados pessoais.

The image shows a registration form titled "Verifique os seus dados". It has a sub-header "Uma nova conta será criada com o endereço de e-mail que compartilhou conosco." Below this is a label "Digite seu email" above a text input field. The input field contains the email "rafaela.radames@gmail.com" and has a green checkmark icon on the right. At the bottom of the form is a blue button labeled "PROSSEGUIR".

Figura 2: E-mail preenchido automaticamente

CT-03: Gestão de Sessão e Desconexão (Logout)

- **Procedimento:** Realização do login, acesso ao perfil, clique na opção "Sair" e acionamento do botão "Voltar" do navegador.
- **Observação:** O sistema redirecionou o usuário imediatamente para a tela de login, sem exibir dados em cache.
- **Impacto em NFR:** Segurança da Sessão (Positivo). Confirma que a sessão foi invalidada no servidor, protegendo o usuário em computadores públicos.



The image shows the Decathlon login page. At the top left is a home icon and the text 'Voltar ao site'. At the top center is the Decathlon logo. Below the logo is the heading 'Login'. Underneath is the instruction 'Digite seu email'. There is a text input field labeled 'Email'. Below the input field is a blue button with the text 'PROSSEGUIR'. Further down are three social login options, each with a logo and a button: 'Continuar com Google' (Google logo), 'Continuar com Facebook' (Facebook logo), and 'Continuar com Apple' (Apple logo).

Figura 3: Página retornada após logout

CT-04: Cadastro manual e autenticação por OTP

- **Procedimento:** Início do cadastro manual utilizando um e-mail válido.
- **Observação:** O sistema enviou um código de verificação de 6 dígitos por e-mail com validade de 15 minutos. Permite também o login direto via "senha de uso único" sem necessidade de senha fixa.
- **Impacto em NFR:** Autenticidade (Positivo). Valida a posse do e-mail por meio de token temporário.



The image shows a page for OTP verification. The heading is 'Preencha com o código recebido:'. Below it is the instruction 'Digite o código de verificação de 6 dígitos que foi enviado por e-mail para:'. The email address 'rafaela.andrea@hotmail.com' is displayed, with a 'Modificar' link to its right. Below this is a green status bar with a checkmark icon and the text 'O código foi enviado.'. Underneath is a row of six input boxes for the digits. At the bottom is a blue button with the text 'PROSSEGUIR'.

Figura 4: Sistema aguardando a inserção do código de verificação

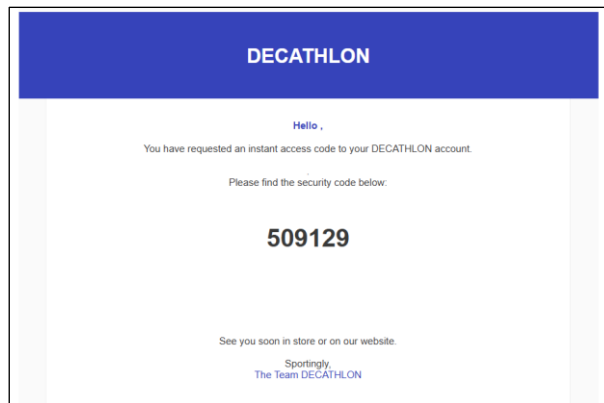


Figura 5: Código de verificação enviado por e-mail

CT-05: Regras de complexidade e validação de CPF no cadastro

- **Procedimento:** Criação de senha e preenchimento de dados cadastrais.
- **Observação:** A senha exige no mínimo 8 caracteres, 1 letra maiúscula, 1 minúscula, 1 número e 1 caractere especial. Ao tentar usar um CPF já cadastrado em outra conta, o sistema bloqueou com o alerta *"Ops! Este CPF já está vinculado a outro e-mail"*.
- **Impacto em NFR:** Integridade e Unicidade (Positivo). Impede duplicidade de contas por CPF e força credenciais fortes.

A password creation form titled 'Senha'. It shows the email 'rafaela.andrea@hotmail.com' with a 'Modificar' link. Below is the instruction 'Criar uma senha' and a password input field labeled 'Senha' with a visibility icon. To the left of the input field are requirements: '1 maiúscula', '1 número', and 'Não utilize "espaço"'. To the right are: '1 minúsculo', '8 caracteres', and '1 special character'. At the bottom is a large blue 'CONFIRMAR' button and a link 'CRIAR UMA SENHA MAIS TARDE'.

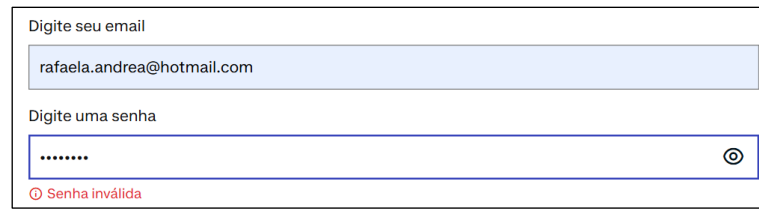
Figura 6: Etapa de criação de senha



Figura 7: Alerta de CPF já usado em outra conta cadastrada

CT-06: Cenário de falhas consecutivas de senha

- **Procedimento:** Inserção deliberada de senha incorreta por 5 vezes consecutivas para o mesmo e-mail.
- **Observação:** Nas 5 tentativas, o sistema respondeu repetidamente com a mensagem "*Senha inválida*", sem aplicar bloqueio temporário (*lockout*) ou desafio CAPTCHA.
- **Impacto em NFR:** Resiliência / Defesa contra Força Bruta (Falha). Torna a conta vulnerável a ataques automatizados de adivinhação de senha.



Digite seu email

rafaela.andrea@hotmail.com

Digite uma senha

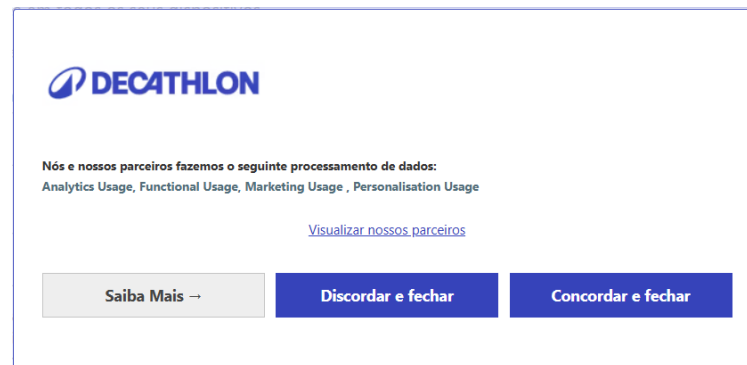
.....

Senha inválida

Figura 8: Resposta do sistema a senha digitada incorretamente

CT-07 & CT-08: Alteração de senha e fluxo de notificações

- **Procedimento:** Acesso ao painel de Segurança para alteração de senha.
- **Observação:** O sistema exigiu a senha atual. Ao tentar definir a mesma senha que já era utilizada, o sistema bloqueou exibindo "*Introduz outra palavra-passe*". Contudo, nenhum e-mail de notificação de alteração de senha foi recebido após a conclusão.
- **Impacto em NFR:** Integridade (Positivo) pela trava de reutilização, mas Falha de Rastreabilidade/Alerta (Negativo) pela ausência do e-mail de confirmação.



DECATHLON

Nós e nossos parceiros fazemos o seguinte processamento de dados:
Analytics Usage, Functional Usage, Marketing Usage, Personalisation Usage

[Visualizar nossos parceiros](#)

Saiba Mais → Discordar e fechar Concordar e fechar

Figura 9: Procedimento de confirmação de alteração de senha

Figura 10: Etapa do processo de alteração de senha

CT-09 & CT-10: Fragmentação de interface e conformidade LGPD

- **Procedimento:** Navegação avançada no menu "A minha conta".
- **Observação:** Ao acessar a gestão de perfil completa, o usuário é transferido para uma interface com layout, menu e estilo visual diferentes da loja. Neste ambiente, é exibido o cartão do clube e opções de privacidade. Na aba Privacidade, está disponível a opção "Eliminar a minha conta".
- **Impacto em NFR:** Consistência Visual (Desvio) devido à fragmentação de sistemas; Conformidade Legal (Positivo) pelo cumprimento do direito ao esquecimento da LGPD.

Figura 11: Menu "Minha Conta" após processo de alteração de senha – Quebra de interface



Figura 12: Menu "Preferências e Personalização" após processo de alteração de senha – Quebra de interface

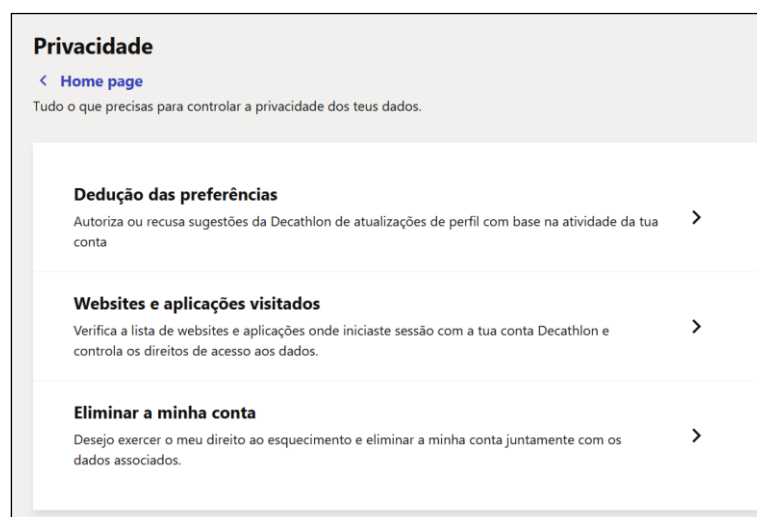


Figura 13: Menu "Privacidade" após processo de alteração de senha – Quebra de interface

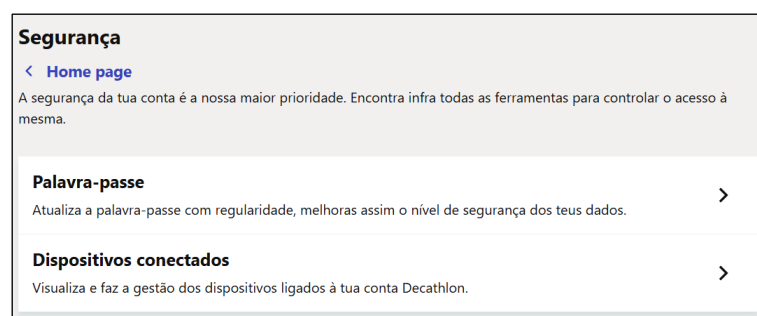


Figura 14: Menu "Segurança" após processo de alteração de senha – Quebra de interface

CT-11: Fluxo de Recuperação de Senha ("Esqueci minha senha")

- **Procedimento:** Acionamento do link "Esqueci minha senha" na tela de login e inserção de e-mail válido.
- **Observação:** O sistema dispara um e-mail com instruções e link/código de uso único com tempo de expiração determinado para a redefinição das credenciais.
- **Impacto em NFR: Recuperabilidade (Positivo).** Garante o restabelecimento do acesso à conta pelo usuário legítimo por canal seguro secundário.

The login form is titled "Login". It contains two input fields: "Digite seu email" with the value "rafaela.andrea@hotmail.com" and "Digite uma senha" with the placeholder "Senha". To the right of the password field is an eye icon. Below the fields is a blue button labeled "CONFIRMAR". At the bottom, there are two links: "Esqueceu sua senha?" and "Obtenha uma senha de uso único".

Figura 15: Opções de login - Fluxo de recuperação de senha

The form is titled "Esqueceu sua senha?". It asks the user to "Digite o código de verificação de 6 dígitos que foi enviado por e-mail para:" followed by the email "rafaela.andrea@hotmail.com" and a "Modificar" link. Below this, a message states "O código será enviado em 7 segundos" with a refresh icon. There is a row of six empty input boxes for the verification code. At the bottom is a blue button labeled "PROSSEGUIR".

Figura 16: Sistema aguardando inserção de código de recuperação de senha



Figura 17: E-mail recebido com código de recuperação de senha

CT-12: Acesso por Senha de Acesso Único

- **Procedimento:** Escolha da opção de login por "senha de uso único" ou código pontual enviado por e-mail.
- **Observação:** O sistema valida a identidade enviando um token temporário diretamente para a caixa de entrada, permitindo o acesso direto sem a necessidade de digitação de senha mestra.
- **Impacto em NFR: Usabilidade vs. Autenticidade (Positivo).** Reduz a necessidade de memorização de senhas, mantendo a validação por posse de e-mail.

Preencha com o código recebido:

Digite o código de verificação de 6 dígitos que foi enviado por e-mail para:
rafaela.andrea@hotmail.com [Modificar](#)

ⓘ O código será enviado em 8 segundos

--	--	--	--	--	--

PROSSEGUIR

Figura 18: Sistema aguardando inserção de código de acesso único

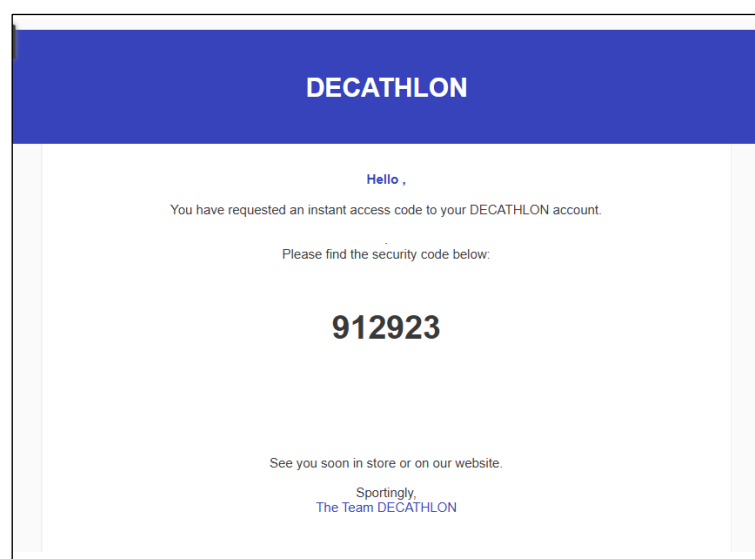


Figura 19: Código de acesso único recebido por e-mail

4. ANÁLISE CRÍTICA DOS RESULTADOS

A consolidação dos testes empíricos permitiu diagnosticar o nível de maturidade do sistema Decathlon em relação aos seus Requisitos Não-Funcionais (NFRs). A análise detalhada das evidências aponta tanto pontos fortes consolidados quanto vulnerabilidades operacionais que demandam mitigação.

4.1. Vulnerabilidades de Segurança e Privacidade

- **Exposição à Enumeração de Usuários:** A resposta diferenciada no fluxo de verificação de e-mail (CT-01) expõe o estado do cadastro do usuário. Esta falha viola o atributo de Confidencialidade, permitindo que agentes maliciosos construam listas de alvos válidos para ataques direcionados de *phishing* ou *credential stuffing*.
- **Ausência de Mecanismo de Defesa contra Força Bruta:** A ausência de bloqueio de conta, limitação de taxa ou aplicação de CAPTCHA após 5 tentativas incorretas consecutivas (CT-06) compromete a Resiliência da autenticação.
- **Falha na Rastreabilidade de Incidentes de Segurança:** A falta de notificação por e-mail no momento em que uma senha é alterada (CT-08) quebra o NFR de Rastreabilidade. Caso ocorra o sequestro de uma conta, o usuário legítimo não possui aviso imediato para acionar medidas de contenção.

4.2. Usabilidade, Arquitetura e Conformidade

- **Inconsistência Visual e Arquitetura SSO Fragmentada:** A transição abrupta de layout e estilo visual observada no acesso aos dados de perfil e segurança (CT-09) evidencia a integração entre a loja virtual e um subsistema de SSO centralizado. Sob a ótica de Usabilidade, essa divergência gera estranhamento e reduz a percepção de continuidade do ambiente.
- **Fricção na Autenticação Social e Coleta de Dados:** O fluxo de cadastro via login social exige 6 etapas/cliques e condiciona a continuidade ao consentimento de e-

mails promocionais (CT-02). Há um conflito direto entre a Usabilidade (que busca um fluxo ágil) e a estratégia de coleta de dados de marketing da plataforma.

- **Pontos Fortes de Conformidade e Proteção de Sessão:** Positivamente, o sistema atende aos Requisitos Não-Funcionais de Integridade (regras fortes de senha e bloqueio de CPF duplicado) (CT-05), Segurança da Sessão (invalidação eficaz de cache pós-logout no CT-03) e Conformidade Legal com a LGPD (oferta explícita do direito ao esquecimento no CT-10).
- **Mecanismos Alternativos de Acesso e Recuperabilidade:** A disponibilização da senha de acesso único (CT-12) e do fluxo de recuperação de conta (CT-11) demonstra uma maturidade positiva nos NFRs de Usabilidade e Recuperabilidade. A oferta de autenticação *passwordless* simplifica a jornada de usuários ocasionais sem comprometer a Autenticidade, já que a validação permanece atrelada à posse da conta de e-mail do titular.

5. CONSIDERAÇÕES FINAIS

A realização dos ensaios de teste e o processo de engenharia reversa comportamental na plataforma web da Decathlon permitiram mapear com precisão o comportamento operacional dos fluxos de autenticação, cadastro e gestão de perfil. A análise empírica revelou um sistema robusto em aspectos de conformidade com a LGPD, complexidade de senhas e gestão de sessão, porém com lacunas críticas de segurança, como a exposição a ataques de enumeração de usuários e a ausência de trava contra força bruta (*lockout*).

Este levantamento cumpriu integralmente seu papel de base empírica do estudo. Os comportamentos registrados, as falhas identificadas e as métricas de usabilidade e segurança levantadas nestes testes forneceram os dados concretos necessários para fundamentar os próximos passos da disciplina. A partir destas evidências, foi possível elaborar com a modelagem dos demais artefatos do projeto, garantindo que a especificação dos Requisitos Não-Funcionais (NFRs) reflita as reais necessidades e vulnerabilidades do sistema analisado.

REFERENCIAS BIBLIOGRÁFICAS

CANHOTA JUNIOR, Antonio Jorge Sapage da; SOUZA, Diego Alves de; MOUTINHO, Diogo dos Santos; LOHNEFINK, Felipe Paixão. Engenharia Reversa. 2005. Trabalho apresentado à disciplina Informática I, Curso de Ciência da Computação, Universidade Federal Fluminense, Niterói, 2005.

VALENTE, Marco Tulio. Engenharia de Software Moderna: Princípios e Práticas para Desenvolvimento de Software com Produtividade. Disponível em: <https://engsoftmoderna.info/>